System Vulnerability Assessment

Course code: CYS 330

Course Lecturer: Paul M. Mutunda

Objective(s)

- **Conduct** vulnerability assessment activities like vulnerability scanning, research analysis, and reporting
- **Provide** insight into establishing or enhancing the vulnerability management process in the organisation
- **Integrate** advisories and alerts into your security practices and procedures
- **Respond** to evolving risk levels by prioritizing your defensive resources.
- **Manage** ongoing vulnerability assessment.

2. Vulnerability Research – Unit Two

Objective(s) for Unit Two

- **Understand** the different criteria in selecting a vulnerability assessment technology with ease
- **Conduct** vulnerability assessment activities like vulnerability scanning, research analysis, and reporting correctly

Tasks for Unit Two

✓Vulnerability Research
✓Vulnerability categories
✓The Common Vulnerability and Exposures (CVE)
✓Vulnerability Information
✓Resources
✓What to look for
✓Test one based on unit one and unit two

Vulnerability Research

- This is a crucial concept in research ethics.
- It is actively involved in discovering critical vulnerabilities in software and hardware products as part of its ongoing research and development efforts. It also involves analysing the integrity of information systems and software to identify and study security vulnerabilities.
- It aims to improve security by discovering unexpected behaviour or vulnerabilities that could be exploited by attackers.
- Techniques used for vulnerability research include
- Code auditing, fuzzing, and reverse engineering

Vulnerability Research

- Researchers often conducts black box or white box testing and may develop exploits for newly discovered vulnerabilities.
- **Disassembler:** Breaks down executable files into assembly code
- **Debugger:** Allows dynamic analysis with breakpoints in programming
- **Decompile:** Converts machine code into high-Level code for easier analysis
- **Scripting:** Supports automation and customization using Javascripts
- **Extensibility:** Users can develop plugins to enhance functionality . Note that plugins are software components or extensions that add specific functionality to an existing application or website without altering its core code at all. They are widely used to enhance features, improve performance, and integrate third party tools.

Vulnerability Research

- Take note of the following important aspects:
- **Vulnerability discovery and evaluation:** Focuses on identifying critical vulnerabilities in both software and hardware in a network or applications. This research helps to better understand, leverage, and reinforce operating system and application security.
- By uncovering vulnerabilities, they contribute to improving overall cybersecurity.

Vulnerability Research

- **Threat Analysis and reporting:** Researchers engage in reverse engineering of threat vectors.
- They analyze or assess the impact of the malware samples found to understand their exploitation, hiding and evasion methods. Assessment of the impact of vulnerabilities and documenting the findings.
- The analysis helps to determine the intended purpose of threats, the skill level of their authors, and their relationship to previously analysed or assessed malware.

Vulnerability Research cont.

- **Security Evaluation:** Vulnerability Research adopts an offensive mindset to evaluate security. Their experienced penetration testers and system administrators assess whether an organization's security plans and posture can withstand sophisticated attacks.
- However, by working closely with customers, they tailor security assessments to match the desired risk level.
- **Mitigation and exploitation:** Providing recommendations for patching or securing identified vulnerabilities to prevent exploitation

Vulnerability Research cont.

- **Vulnerability Research** can also foster a collaborative determined environment.
- The team for collaborative meetings could include software engineers, system Administrators, IT specialists, technical writers, graphic artists and so on.
- It brings forth value innovation, teamwork and impactful work.

Vulnerability Research tools cont.

Disassemblers: converts machine code to assembly lanuagage and is used for reverse engineering, debugging, malware analysis and understanding compiled programs without access to their original source code. Examples include the following:

- **IDA Pro:** This is a leading disassembler used extensively in vulnerability research and reverse engineering.
- It offers powerful disassembly, decompilation, and debugging capabilities, supporting a wide range of processors and file formats
- It is proffered because of its ability to analyze complex binaries and those from embedded systems included as well as mobile applications

Vulnerability Research tools cont.

- it also integrates tools such as FLIRT for library identification and provides plugins such as VulFi to assist in vulnerability discovery
- **IDA Pro** is versatile and extensible making it crucial tool for researchers aiming to understand how software works and identify potential vulnerabilities.
- **Binary Ninja:** It is a versatile reverse engineering platform designed for disassembling, decompiling, and debugging binary files.
- If offers a range of powerful features such as dataflow analysis, cross platform compatibility and scripting API using languages such as Python, RUST and C++.

Vulnerability Research tools cont.

- **Ghidra:** It is an open-source reverse engineering tool developed by the National security Agency (NISA).
- It offers a comprehensive suite of features for disassembling, decompiling, and debugging binary files, making it invaluable for security researchers and analysts.
- It is also used for malware analysis and software debugging across various platforms, including windows, MacOS and Linux other than vulnerability research

Vulnerability Research tools cont.

Debuggers: This is a software tool used to identify, analyse, and fix errors in computer programs. It allows developers to test and debug their code through breakpoints, step-by-step execution, viewing memory and CPU registers, and modifying program states during runtime. Examples include the following:

- **GDB/GNU:** This is a powerful and versatile debugging tool used for examining the internal operation of running programs. It supports a wide range of programming languages and processor architectures, making it suitable for platforms like UNIX-like systems, embedded systems, and microcontrollers.
- It allows pausing program execution at specific points for inspections. It also displays the call stack to understand function calls leading up to an error. Further, it performs disassembling by enabling viewing machine code instructions for low level analysis. It helps dragonize crashes by examining program memory states (core Dump analysis). Lastly, it supports automation using programming languages like python and Guile

Vulnerability Research tools cont.

- **Windows Debugger (WinDBG):** This is a powerful tool developed by Microsoft for debugging windows applications, drivers, and the operating system. It is part of the debugging tools for windows suite and offers a range of features such as Crash Dump analysis on crashed files (.dmp), live debugging for real-time debugging, kernel debugging, Time travel debugging (TTD), and scripting and extensions. It can be used by software developers, Systems Administrators, and Cybersecurity Professionals for troubleshooting complex software issues and analysing malware.

Vulnerability Research tools cont.

- **OllyDbg:** It is a 32-bit assembler level debugger for windows, widely used in RE and malware analysis. It is useful when source code is not available, as it allows users to analyze binary code directly. It traces registers, recognises procedures, and API calls in analysing binary codes. It supports both hardware as well as software breakpoints for pausing program execution. It is used to dissect and understand malware by analysing its binary code. Other than cybersecurity professionals for RE, it can be used by programmers or software developers too!

Vulnerability Research tools cont.

Web Proxies: This is an intermediary server that facilitates communication between a client device such as a web browser and the destination server. It routes web requests, mask the IP addresses for the users, and can provide additional functionalities like catching, filtering and enhancing security. Examples are as follows;

- **Burp Suite:** This is a comprehensive tool for web application security testing widely used for vulnerability scanning, pen testing, and web application security auditing. It has the following important features;
- **Proxy:** Acts as an intercepting proxy to inspect and modify HTTP requests and responses between the browser and the web server.

Vulnerability Research tools cont.

- **Scanner:** Automatically scans web applications for vulnerabilities like SQLi and XSS.
- **Intruder:** Automates customised attacks such as fuzzing and brute forcing to identify vulnerabilities.
- **Repeater:** Allows manual customization and resending of HTTP requests for iterative testing.
- **Decoder and Comparer:** Tools for decoding and comparing data to aid in analysing

Vulnerability Research tools cont.

- **OWASP ZAP (Zed Attack Proxy):** Used for identifying vulnerabilities in web applications. It acts as a proxy between the browser and the web server, intercepting and analysing HTTP requests and responses to detect security issues such as SQLi, XSS and XSRF. It can be used for both passive and Active scanning. It is also effective for JavaScript-heavy applications by navigating web pages and rendering JavaScript **(Ajax spider).**
- **Fuzzer:** Sends unexpected data inputs to test application robustness.
- **Automation support:** Integrates with **Continuous Integration/Continuous development (CI/CD)** for manual and auto testing

Vulnerability Research tools cont.

- **Charles Proxy:** This is a web debugging tool that acts as a man-in-the-middle for HTTP/HTTPS communication, allowing developers to inspect and modify network traffic.
- **SSL Proxying:** Enables debugging of HTTPS sessions by intercepting encrypted traffic.
- **Bandwidth Throttling:** Simulates different network conditions to test application behaviour under various speed aspects
- **Request/Response Modification:** allows modifying requests and responses on the fly to simulate different scenarios.
- **Traffic inspection:** Provides detailed views of HTTP headers, cookies, and request/response bodies.
- **Mobile App debugging:** Useful for analysing network calls from iOS and Android apps
- **CP** is used for testing APIs, debugging web applications and optimizing network performance

Vulnerability Research tools cont.

Code Review Tools: This is a software application designed to assist developers in reviewing and managing code changes by streamlining the code review process, providing features such as analysis, side-by-side code comparisons, commenting systems, and integration with version control systems such as GitHub or GitLab.

- **GitHub** is a widely used platform for version control and collaboration, primarily designed for hosting and managing software development projects. It integrates Git, a distributed version control system, with additional features to streamline workflows for developers.
- **GitLab** is a comprehensive platform that provides tools for version control, CI/CD pipelines, and code reviews widely used by programmers or software developers to streamline processes.

The following are some tools used for this purpose;

Vulnerability Research tools cont.

- **Review Board:** This is an open-source web-based tool for code and document reviews. It is designed to enhance collaboration and code quality by providing a platform for detailed feedback and discussion on code changes.
- **Automated analysis:** Integrates with CI solutions such as Jenkins and CircleCI for automated code reviews.
- Customised workflow: Allows teams to tailor the review process to their needs.
- **Rich Diff Viewer:** Displays code changes with syntax highlighting and moved line detection.
- **Document Review:** Supports viewing various document types, including PDFs and images with contextual commenting.

Vulnerability Research tools cont.

Code Review Tools

- **Review Board:** This is an open-source web-based tool for code and document reviews. It is designed to enhance collaboration and code quality by providing a platform for detailed feedback and discussion on code changes.

Vulnerability Research tools cont.

- **Coverity:** This is a static Application security tesing (SAST) tool developed by synopsis.
- It is designed to identify software vulnerabilities and code quality issues early in the development lifecycle by analysing source codes without requiring it to run. Its strength is as follows;
- **Static Analysis:** Scans source codes to detect vulnerabilities such as Cross – Site Scripting (XSS), SQL injection and buffer overflows.
- **Broad Language:** It supports multiple programming languages such as Java, C#, C, C++ and scripting languages such as JavaScript.
- **High Accuracy:** Provides actionable findings with low false positives, improving developer trust and adoption.

Vulnerability Research tools cont.

- **Compliance reporting:** Generates reports aligned with security standards such as OWASP, Top 10, CWE Top 25, PCI DSS and SEI CERT.
- **Code Sight Plugin:** Offers in-IDE guidance for developers with remediation advice to fix issues as they code.
- **Integration with DevOps:** Easily integrates into CI/CD pipelines, IDEs and build systems for seamless security testing

Vulnerability Research tools cont.

SonarQube: This is an open-source platform developed by SonarSource for continuous code quality inspection.

- It uses static and dynamic analysis to detect bugs, vulnerabilities, and code smells across multiple programming languages.
- **Multi-Language Support:** Supports 29+ languages such as Java, Python, C++, Kotlin and scripting languages such as JavaScript.
- Shares other similar features with the above.

Vulnerability Research tools cont.

File Format Analysis: This is the process of examining the structure, content, and metadata of files to understand their formats, identify potential issues or extract useful information commonly used in digital forensics, reverse engineering, malware analysis, and software development. Here are some examples that fall under this category as its tool:

Vulnerability Research tools cont.

- **Binwalk:** This is an open – source software designed for analysing and extracting data from binary files and firmware images. It is widely used in reverse engineering, security research, and digital forensics. Some of its features include such things as;
- **Signature – based scanning:** identifies embedded file types, compressed archives, executables and file systems within binaries using a database of magic signatures.
- **Data Extraction:** Extracts specific components like file systems, kernels or executables from firmware images.
- **Entropy Analysis:** Detects regions of high entropy, often indicative of compressed or encrypted data.
- **Custom signatures:** Allows users to define custom patterns for proprietary file formats or encryption schemes

Vulnerability Research tools cont.

- **Recursive scanning:** Analyses nested files and directories within firmware images.
- **Integration with other tools:** Supports plugins and python programming scripting for extended functionality.

Applications

1. **Firmware analysis:** Dissecting firmware from IoT devices or embedded systems to identify vulnerabilities or hidden backdoors.
2. **Reverse Engineering:** Understanding the structure and functionality or binaries.
3. **Digital Forensics:** Extracting evidence from binary files during investigations

Vulnerability Research tools cont.

- **TrID file Identifier:** This is a tool used to identify file types based on binary signatures. It helps analyze unknown files and determine their formats, often used in digital forensics or reverse engineering.
- It is useful when dealing with files that lack extensions or have incorrect ones, making it difficult to determine their formats.
- **Signature based Identification:** It uses a database of file signatures to identify file types.
- **Multi-Platform Support:** Available for Windows, MacOS and Linux.
- **Command – Line Interface (CLI):** Offers a CLI version for automation and scripting
- Can be used for **digital forensics**, **reverse engineering** and **file recovery.**

Vulnerability Research tools cont.

- **PE viewer:** A tool used to analyze and view the structure of PE files, which are executable files used by windows.
- PE Viewers involve examining PE files to identify their components such as imports, exports, and sections. This is often done in reverse engineering or malware analysis to understand how a program works or to detect malicious behaviour.
- **PE file structure analysis:** Displayed detailed information about the PE file format, including headers, sections, imports, exports and resources.
- **Resource editing:** Some viewers allow editing of resources like icons, strings, or dialog boxes embedded in executable
- **Section viewing:** Allows users to examine each section of the PE file such as code data, and resources.

Vulnerability categories

This helps organise and understand the various types of security risks that can affect systems, software, networks and the servers. The following are some common categories and some examples;

1. **Software Vulnerabilities**

(a) **Buffer overflow:** Exceeding buffer capacity, potentially, allowing code execution.

(b) **SQL injection:** Injecting malicious codes to manipulate databases.

(c) **Cross – Site Scripting (XSS):** injecting scripts into web pages to steal user data

(d) **Outdated and unpatched software:** Running outdated or unpatched software exposes systems to known vulnerabilities.

- Regular software updates and patches are important to mitigate risks

Vulnerability categories

2. **Network Vulnerabilities**

(a)Firewall misconfigurations: Incorrect configured firewalls allowing unauthorised access.

(b)Denial of service (DoS): Overwhelming a system with requests to make it unavailable

(c)Man-in-the-middle MitM): Intercepting communication between two parties.

Vulnerability categories

3. **Configuration and process Vulnerabilities**

(a) **Default passwords:** Using unchanged default passwords for devices or systems

(b) **Misconfigured Access Controls:** Incorrectly set permissions allowing unauthorised access to a system

(c) **Insecure data storage:** Storing sensitive data without proper encryption.

Vulnerability categories

4. Resource Management Vulnerabilities: These are vulnerabilities that arise from the improper management of systems resources such as storage or memory, and CPU. Vulnerabilities such as data breaches, unauthorised access and system crash are common here.

(a) Memory corruption: Unintended changes to memory, potentially leading to code execution

(b) Path traversal: Accessing unauthorised directories by manipulating file paths

(c) Buffer overflow: When more data is written to a buffer than it is designed to hold, potentially, allowing attackers to execute malicious codes

(d) Use-After-Free (UAF): Using memory after it has been freed, which can lead to unpredictable behaviour or code execution.

Vulnerability categories

(e) **Dangling pointers:** Pointers that point to memory locations that have already been freed, potentially, causing crashes or data corruption.

(f) Resource starvation: Preventing process from accessing necessary CPU resources, causing it to fail or become unresponsive

Mitigation: Implement memory safety tools like **AdressSanitiser** to detect memory issues.

Implementing Access Controls to ensure proper permissions and authorization to a resource

Vulnerability categories

5. Application Programming Interface (APIs) and web application Vulnerabilities

(a) API Abuse: Misusing APIs to gain unauthorised access or data

(b) Session management vulnerabilities: Failing to properly manage user sessions, leading to unauthorised access

(c) Unsecured Application Programming Interfaces (APIs): These pose a significant vulnerability.

- Attackers exploit weaknesses in APIs to gain unauthorised access.
- Proper API security measures are crucial to prevent breaches.

Vulnerability categories

This helps organise and understand the various types of security risks that can affect systems, software, networks and the servers. The following are some common categories and some examples;

1. Misconfigurations: These are the single largest threat to both cloud and application security.

- Errors during manual configuration can lead to vulnerabilities.
- Common examples here would include misconfigured S3 buckets that become entry points for attacks.
- Organisations and Government Departments should adopt security tools, automate configurations, and reduce human error risks.

Vulnerability categories cont.

4. **Zero day vulnerabilities also known as “0 – day”**

- These are unknown and unpatched.
- This is simply a security hole or vulnerability in a computer system that is known to its owners, developers or anyone capable of mitigating it until the vulnerability is remediated.
- It refers to the number of days since a new piece of software was released to the public. This means that zero day software was obtained by hacking into a developers computer before the official release.
- Overtime, the term was applied to the vulnerabilities that allowed such hacking, and to the number of days that the vendor had to fix them.
- Threat actors or attackers can exploit it in a zero day exploit or zero day attack.

Vulnerability categories cont.

Characteristics of zero-day vulnerability

- It exists in a version of an operating system, application, or device from the moment its released, but the software vendor or hardware manufacturer isn't aware of it.
- The vulnerability can remain undetected for days, months or even years until someone discovers it. Regardless of who discovers the flaw, it often becomes public knowledge soon after.
- Zero day attacks involve malicious actors using zero day exploits to plant malware, steal data, or cause damage to users, systems and organisations.

Vulnerability categories cont.

Window of vulnerability

- The time from when a software exploit first becomes active to when the number of vulnerable systems shrinks significantly, is known as **window of vulnerability**.
- Key events in this timeline include the following;
- **t0:** The vulnerability is discovered
- **t1a:** A security patch is published by the software vendor
- **t1b:** An exploit becomes active
- **t2:** Most vulnerable systems have applied the patch.

Vulnerability Categories cont.

The formular for the length of the window of vulnerability is:

t2 – t1b

- **Note** that t0 is not the same as day zero. For example, if a Hacker discovers the vulnerability at t0, the vendor might not learn of it until much later (on day zero)
- Zero day vulnerabilities are a severe threat because they allow attackers to exploit unknown weaknesses in computer systems.
- Security professionals race against hackers to develop patches and mitigate such risks

Vulnerability Categories cont.

Scenarios

1. A mobile money has signed a MoU with web applications for easy cash payments by their esteemed clients. However, The organisation is receiving complaints of phishing and scam attacks. The organisation has decided to take a serious measure of halting payments until the issue at hand is dealt with. It has been discovered that the problem could be with the API. Discuss what API is.

(a) Discuss in detail on how API works

(b) Explain in detail what vulnerability could be traced in the API

(c) Discuss possible implications of such vulnerabilities

(d) Explain briefly, mitigation plans in future to overcome such vulnerabilities

(e) Explain briefly, remediation plans for such vulnerabilities in APIs.

(f) Write a Technical Report addressed to both organisations based on your Vulnerability Management on these APIs.

Vulnerability Categories cont.

Scenarios

2. As a follow, up question, the system also uses cloud computing. It was discovered that the system had hypervisor vulnerabilities.

(a) Explain in detail what a hypervisor is

(b) Discuss hypervisor vulnerabilities

(c) Explain some mitigation methods for these vulnerabilities

(d) Explain in detail, remediation plans to be implemented in such an environment

(e) List and explain some of the services offered by the cloud

Vulnerability Categories cont.

- A **hypervisor** is a **Virtual monitoring machine (VMM)** considered to be a software, firmware as well as a hardware that enables multiple virtual machines to run on a single physical machine.
- It is primarily used to abstract and manage the underlining hardware resources such as the CPU, memory and storage, allowing each VM to operate independently with its on operating system and applications.

Vulnerability Categories cont.

- **Type 1 (Bare-Metal):** Runs directly on the physical hardware without an underlining operating system. Examples here include VMware ESXi, Microsoft Hyper-V, and Xen which are commonly used for commercial purposes.
- **Type 2 (Hosted)** Runs on top of an already existing operating system. Examples here include VMware workstation and Oracle VirtualBox. These are typically used for personal or development purposes.

Vulnerability Categories cont.

Applications

1. Server virtualization in data centres
2. Cloud computing infrastructure
3. Testing and development environments
4. Running multiple operating systems

Vulnerabilities

1. Exploiting vulnerabilities where attackers can attack security flaws in the hypervisor to execute arbitrary codes, escalation privileges, or bypass security controls
2. VM Escape: An attacker can break out of a VM to access the host hypervisor or other VMs, potentially, gaining access to the entire system
3. Hyperkacking
4. DoS

Cont.

- Attack vector for zero day vulnerabilities include **rogue websites (Fraudulent sites that mimic legitimate websites, and often, infringe on intellectual property (IP) rights)**, **cybersquatting, typosquatting** and malicious email attachments, and exploits targeting common file types.
- **Cybersquatting** can also be known as **domain squatting**, and is a practice of registering, trafficking in, or using an internet domain name with a **bad faith intent to profit the good will of a trademark belonging to someone else.** Its purpose is usually monetary gain or malicious intents. E. g, a cybersquatter might register a domain name that closely resembles a well known brand such as Kaps Mwakasa University instead of Kapasa Makasa University. Then, they will try to sell it to the legitimate trademark owner at an inflated price.
- This can be overcome by reporting to relevant regulatory bodies such as **World Intellectual Property Organisation (WIPO)** which provides an administrative process called the **Uniform Domain Name Dispute Resolution Policy (UDRP).** This can resolve domain disputes.

Cont.

- **Typosquatting (URL hijacking):** This is a form of cybersquatting that relies on mistakes made by internet users when inputting a website address into a web browser. In other words, it occurs when a user accidentally enters an incorrect website address due to typos or misspellings.
- Instead of reaching the intended site, the user is lead to an alternative website owned by cybersquatter.
- There are different types of typosquaters URLs such as common misspelling, typographical error, plural or singular Domain Name, etc.
- The window of vulnerability represents the critical time during which early detection, patching, and mitigation are essential to prevent exploitation.
- Timely security patches and proactive measures help reduce this window and enhance overall system security.

Vulnerability Categories cont.

5. **Weak or stolen user credentials**

- Weak passwords, or stolen credentials provide easy access for attackers.
- Implement strong authentication mechanisms and educate users about secure practices
- Stolen credentials are available for sale on the **dark web**. Threat actors steal credentials to sell them to the highest bidder.
- High privilege accounts: credentials with high privileges such as finance, or network access command a higher price.
- **Brute Force attacks, default credentials, modern Ransomware and Dark web Marketplaces** fall under this category.

Vulnerability categories cont.

- Another factor is that of **trends**. Remote work and cloud solutions have shifted the attackers mindsets.
- **Multi-factor Authentication (MFA):** Lack of MFA or poorly implemented MFA is a common security weakness.

Access Control or Unauthorised Access

- Inadequate access controls allow unauthorised users to gain entry.
- Proper access management and permissions are critical.

6. **Misunderstand the share responsibility**

Vulnerability categories cont.

- Organisations often misunderstand their responsibilities in cloud environments
- Failing to address shared responsibilities can lead to security gaps.
- Cloud Service Providers (CSP) are responsible for securing the underlying cloud infrastructure which include physical facilities, hardware, and network components.
- Customer responsibility: customers are responsible for securing their data, applications and configurations within the cloud environment. It involves network controls, identity and access management, and application settings.

Vulnerability categories cont.

Misunderstandings and implications

- Many organizations still have trust issues with the cloud. However, it is the responsibility of the organisation to secure their cloud. This itself, is a misunderstanding. In this case, customers should understand their responsibilities based on the services they consume.
- On the other hand, the organisation should be able to implement security best practices within their organisation.
- There should be collaboration with CSPs to ensure a holistic security approach.

Common Vulnerability Exposures (CVE)

- **CVE** is a standard used to **identify, define,** and **catalog** publicly disclosed cybersecurity vulnerabilities.
- It is a global initiative
- Its mission is as in the definition, to
- **Identify** vulnerabilities
- **Define** their characteristics and
- **Catalog** them in a standardized format
- CVE provides a common language for discussing and sharing information about security vulnerabilities.

Common Vulnerability Exposures (CVE) cont.

- **CVE Records** include details about specific vulnerabilities.
- Such records are added to the **CVE list** by **CVE Numbering Authority (CNAs)**
- **CNAs** play an important role in the CVE programs by successfully contributing to the catalog of vulnerabilities.
- **Accessing CVE information:** This can be done through accessing the **CVE list** on the **CVE website.**
- The list includes information about newly published CVE Records, product versions and more other information.
- The website provides search capabilities to find specific vulnerabilities.

Common Vulnerability Exposures (CVE) cont.

Transition to the New CVE website

- The legacy CVE download formats are being depreciated and will end possibly on the **last day of June, 2024.**
- The new CVE website offers improved features, including podcasts, blogs, and news update.

Common Vulnerability Exposure (CVE) cont.

- **CVE-2023-39683**: This vulnerability involves a **Cross Site Scripting (XSS)** issue in the **EasyEmail** software (version 4.12.2 and earlier). A local attacker can execute arbitrary code via user input parameters. It is claimed by the Researcher that the issue exists in all versions prior to and later than the tested version
- **CVE-2024-20353**:
- **Description**: **Cisco Adaptive Security Appliance (ASA)** and **Firepower Threat Defense (FTD)** suffer from an infinite loop vulnerability, leading to remote denial of service.
- **Severity**: Unknown (but actively exploited)
- **CVE-2024-29988**:
- **Description**: **Microsoft SmartScreen Prompt** contains a security feature bypass vulnerability. Attackers can use this in conjunction with other vulnerabilities (such as CVE-2023-38831 and CVE-2024-21412) to execute a malicious file.
- **Severity**: Unknown (but actively exploited)

Common Vulnerability Exposure (CVE) cont.

- **CVE-2023-36268**:
- **Description**: An issue in **The Document Foundation Libreoffice v7.4.7** allows a remote attacker to cause a **denial of service** via a crafted .ppt file.
- **Severity**: Medium
- **CVE-2024-33103**:
- **Description**: An arbitrary file upload vulnerability exists in the **Media Manager component of DokuWiki 2024-02-06a**. Attackers can execute arbitrary code by uploading a crafted SVG file.
- **Severity**: Critical
- CVE-2024 – 33832
- **Description**: OneNav v0.9.35-20240318 contains a **Server-Side Request Forgery (SSRF)** vulnerability via the component/index.php?c=api&method=get_link_info.
- **Severity:** Critical

Common Vulnerability Exposures (CVE) cont.

- **CVE Program**: The mission of the CVE Program is to **identify**, **define**, and **catalog** publicly disclosed vulnerabilities. It provides a standardized way to reference and track vulnerabilities across different products and vendors.
- **CVE Records**: Each vulnerability is assigned a unique **CVE identifier**. These identifiers help security professionals and organizations stay informed about known vulnerabilities. As of now, there are over **233,000 CVE records**.
- **CVE Website**: The CVE program has transitioned to a new website at WWW.CVE.ORG. You can find the latest CVE information there, including newly published records and updates.
- **CVE Numbering Authorities (CNAs)**: CNAs play a crucial role in the CVE Program. They are responsible for adding CVE records to the CVE List. Becoming a CNA allows organizations to contribute to the security community by reporting and managing vulnerabilities.
- **NVD (National Vulnerability Database)**: The NVD, maintained by the National Institute of Standards and Technology (NIST), is another valuable resource. It assigns CVE identifiers to vulnerabilities and provides detailed information about them. For example, here's a recent CVE entry:

Vulnerability information

Sensitive Data Exposure (SDE)

- This issue revolves around the accidental or deliberate **disclosure** of critical information, such as:
- **Personally Identifiable Information (PII)**: This includes data like Social Security numbers (NAPSA), addresses (physical and work related), and other personal details.
- **Payment Card Information (PCI)**: Credit card numbers, expiration dates, and security codes fall under this category.
- **Electronic Protected Health Information (ePHI)such as NHIMA**: Medical records and health-related data are sensitive and require protection.
- **Intellectual Property (IP)**: Trade secrets, proprietary algorithms, and confidential business information fall into this category

Vulnerability information cont.

Web application (SDE) that can be exploited by the attackers

1. **Clear Text Transmission:** If there is clear transmission of data in background in a web application then there might be a risk of data exposure to the attacker. Example – clear transmission of text may includes the credentials of user such as a student in a university.
2. **Cryptographic Algorithm:** Old cryptographic algorithms such as **pigpen cypher** or **Caesar Shift Cipher** that were used in old web apps might be a risk factor. There may be a chance that attackers could have bypass that algorithm and get access to sensitive data.
3. **Cryptographic Keys:** Cryptographic keys always play a vital role in a web applications. If Cryptographic keys are not properly rotated or old & weak keys are used then in that case web application will be at risk of exposure of data.
4. **Encryption:** Web application must enforce proper encryption techniques in order to prevent attacks and to safeguard the confidential information

Vulnerability information cont.

Mitigation Strategies:

- **Encryption**: Encrypt sensitive data at rest and in transit.
- **Access Controls**: Limit access to authorized personnel.
- **Data Masking**: Replace sensitive data with fictional values for non-production environments.
- **Secure Coding Practices**: Avoid hardcoding sensitive data in source code.
- **Regular Audits**: Monitor access logs and review permissions.
- **Data Loss Prevention (DLP)**: Implement DLP solutions to detect and prevent data leaks.

Vulnerability Information cont.

Directory bursting involves systematically attempting to access different directories by guessing their names or enumerating through a list of common directories and file names. The goal is to find hidden or unprotected directories and files on a web server.

- It's often used in **web application security testing** to identify potential vulnerabilities.

How Directory Bursting Work

- Hackers use automated tools alongside **wordlists** to automate directory bursting attacks.
- These tools make HTTP or HTTPS requests for each file name in the wordlist.
- If the directory name exists, the response code and name are recorded and shown.
- A directory brute-forcing tool is only as good as the wordlist it uses

Vulnerability information cont.

Wordlists and Tools:

Wordlists: These are usually .txt files containing thousands of possible directory and file names to be scanned.

Directory Bursting Tools: Some popular tools include:

- **gobuster**
- **dirb**
- **FFUF**
- **dirbuster**
- **git**
- **.htaccess**
- **.backup**
- **/admin**
- **.sql**

Vulnerability information cont.

Hardware vulnerabilities: This refers to weaknesses in a computer system that threatens to exploit digital assets either remotely or physically.

These hardware vulnerabilities include the following

Vulnerability information cont.

2. Meltdown (Variant 3, CVE-2017-5754):

- Meltdown allows attackers to read kernel memory from user space, potentially exposing sensitive data. It impacted a wide range of CPUs and required significant patch coordination efforts.

3. Foreshadow (L1 Terminal Fault):

- Foreshadow vulnerabilities affect Intel CPUs and allow attackers to read data from protected areas of memory, including SGX enclaves and virtual machines.

4. Zombieload (CVE-2019-11091):

- Zombieload exploits speculative execution to leak data from Intel CPUs. It affects both desktop and server processors.

Vulnerability Information cont.

5. Starbleed:

- Starbleed impacts FPGA chips and allows unauthorized access to internal memory. It affects certain Xilinx and Intel Stratix devices.

6. PLATYPUS:

- PLATYPUS targets Intel CPUs and allows attackers to leak data from the CPU's power consumption patterns.

7. SRBDS (Special Register Buffer Data Sampling):

- SRBDS affects Intel CPUs and allows attackers to leak data from special registers. It requires microcode updates and OS patches.

Vulnerability information cont.

- Hardware Vulnerabilities can include susceptibility to humidity, dust, soiling, natural disasters, poor encryption, or firmware vulnerabilities.

1. **Susceptibility to Humidity and Dust**: Excessive humidity can cause corrosion and short circuits in electronic components. Dust accumulation can clog cooling systems, leading to overheating.

Impact: Reduced lifespan of hardware components, potential malfunctions, and increased maintenance requirements.

Mitigation: Keep hardware in controlled environments, use dust filters, and maintain proper ventilation.

Vulnerability information cont.

2. Soiling and Contamination: Soiling refers to dirt, grease, or other contaminants on hardware surfaces.

Impact: Contaminants can interfere with electrical connections, cause overheating, or affect optical components (e.g., camera lenses).

Mitigation: Regular cleaning, protective covers, and proper handling during maintenance.

3. Natural Disasters: Earthquakes, floods, fires, and storms can damage hardware.

Impact: Complete hardware failure, data loss, and disruption of services.

Mitigation: Backup data off-site, use disaster-resistant hardware (e.g., ruggedized laptops), and follow disaster recovery plans.

Vulnerability information cont.

4. Poor Encryption: Weak encryption algorithms or improper implementation can lead to data exposure.

Impact: Sensitive data leaks, unauthorized access, and compromised confidentiality.

Mitigation: Use strong encryption algorithms (e.g., AES), keep software updated, and follow encryption best practices.

5. Firmware Vulnerabilities: Firmware (software embedded in hardware) can have security flaws.

Impact: Attackers can exploit firmware vulnerabilities to gain control over devices.

Mitigation: Regularly update firmware, verify authenticity of updates, and follow manufacturer guidelines.

Vulnerability information cont.

- Physical Site Vulnerabilities: These involve areas subject to natural disasters, unreliable power sources, or lack of keycard access.

1. Natural Disasters: Natural disasters such as earthquakes, floods, hurricanes, or wildfires can significantly impact physical sites.

Impact: Damage to infrastructure, disruption of services, and potential harm to personnel.

Mitigation:

- **Structural Reinforcement**: Design buildings and data centers to withstand seismic activity or extreme weather conditions.
- **Redundancy**: Implement backup power sources (e.g., generators, uninterruptible power supplies) to ensure continuity during power outages.
- **Off-Site Backups**: Regularly back up critical data to off-site locations to prevent loss during disasters.

Vulnerability information cont.

2. Unreliable Power Sources: Sites with unstable or inadequate power sources are vulnerable.

Impact: Unexpected power outages can disrupt operations, cause data loss, and affect equipment.

Mitigation

- **UPS Systems**: Install uninterruptible power supply (UPS) systems to provide temporary power during outages.
- **Generators**: Use backup generators for extended power needs.
- **Power Conditioning**: Stabilize power quality using surge protectors and voltage regulators.

Vulnerability information cont.

3. Lack of Keycard Access: Keycard access controls physical entry to secure areas.

Impact: Unauthorized access by individuals without proper credentials.

Mitigation

- **Access Control Policies**: Define who has access to specific areas and enforce strict access rules.
- **Two-Factor Authentication**: Combine keycards with PINs or biometrics.
- **Regular Audits**: Review access logs and revoke access promptly for terminated employees.

Vulnerability information cont.

- Organizational Vulnerabilities: Improper internal controls, lack of audit, continuity plans, and incident response plans.

The following are some of the items that are termed as Organisational vulnerabilities:

1. Improper Internal Controls: Internal controls refer to policies, procedures, and practices that ensure efficient operations, compliance with regulations, and risk management.

Impact of Weak Controls

- Unauthorized access to sensitive data.
- Inefficient processes.
- Increased risk of fraud or errors.

Mitigation

- Implement robust access controls.
- Regularly review and update internal policies.
- Conduct employee training on security practices.

Vulnerability information cont.

2. Lack of Audit: Audits assess an organization's processes, financial records, and security controls.

Impact of No Audits

- Undetected vulnerabilities.
- Compliance violations.
- Financial losses.

Mitigation

- Conduct regular internal and external audits.
- Address audit findings promptly.

Vulnerability information cont.

3. Continuity Plans: Continuity plans ensure business operations continue during disruptions (e.g., natural disasters, cyberattacks).

Impact of No Continuity Plans

- Downtime.
- Data loss.
- Reputation damage.

Mitigation

- Develop business continuity and disaster recovery plans.
- Test and update these plans periodically.

Vulnerability information cont.

Incident Response Plans: Incident response plans outline steps to take during security incidents (e.g., data breaches, malware outbreaks).

Impact of No Response Plans

- Chaos during incidents.
- Delayed containment.
- Escalated damage.

Mitigation

- Create incident response teams.
- Define roles, communication channels, and incident escalation procedures.

Vulnerability information cont.

- Personnel Vulnerabilities: Poor recruiting policies, lack of security awareness, and downloading malware via email attachments fall into this category.

1. **Poor Recruiting Policies**: Weak recruiting policies can lead to hiring individuals who lack the necessary skills, ethics, or security awareness.

Impact

- Employees without proper qualifications may mishandle sensitive data.
- Inadequate background checks may allow malicious actors to infiltrate the organization.

Mitigation

- Strengthen recruitment processes.
- Conduct thorough background checks.
- Ensure alignment with security policies during hiring.

Vulnerability information cont.

2. Lack of Security Awareness: Employees unaware of security best practices are more likely to make mistakes or fall for social engineering attacks.

Impact

- Phishing attacks succeed.
- Weak password practices.
- Unauthorized sharing of sensitive information.

Mitigation

- Regular security training and awareness programs.
- Each employee should be made aware about phishing, password hygiene, and safe online behavior.

Vulnerability information cont.

3. Downloading Malware via Email Attachments: Employees who open suspicious email attachments can inadvertently introduce malware into the organization's systems.

Impact

- Malware infections.
- Data breaches.
- Disruption of operations.

Mitigation

- Educate employees about email security.
- Implement email filtering and sandboxing.
- Encourage skepticism toward unexpected attachments.

Vulnerability information cont.

- Software Vulnerabilities: Examples include insufficient testing, design flaws, memory safety violations (such as buffer overflows), input validation errors (like SQL injection), and privilege-confusion bugs.

1. **Insufficient Testing**: Insufficient testing occurs when software is not thoroughly tested for various scenarios, edge cases, and security issues.

Impact

- Undetected bugs or security flaws.
- Unexpected behavior during production.
- Increased risk of exploitation.

Mitigation

- Conduct comprehensive testing (unit tests, integration tests, and security testing).
- Use automated testing tools.

Vulnerability information cont.

2. Design Flaws: Design flaws refer to fundamental errors in the software's architecture or logic.

Impact

- Difficult-to-fix vulnerabilities.
- Poor performance.
- Security weaknesses.

Mitigation:

- Perform thorough design reviews.
- Follow secure design principles.
- Consider threat modeling.

Vulnerability information cont.

3. Memory Safety Violations (e.g., Buffer Overflows): Buffer overflows occur when a program writes beyond the bounds of an allocated buffer.

Impact

- Memory corruption.
- Potential code execution by attackers.
- System crashes.

Mitigation

- Use safe programming languages (e.g., Rust, Go).
- Validate input sizes.
- Implement bounds checking.

Vulnerability information cont.

4. Input Validation Errors (e.g., SQL Injection): Input validation errors occur when user input is not properly validated before being processed.

Impact

- SQL injection: Attackers manipulate database queries.
- Command injection: Execution of arbitrary commands.
- Cross-site scripting (XSS): Malicious scripts injected into web pages.

Mitigation

- Use parameterized queries.
- Sanitize user input.
- Implement input validation routines.

Vulnerability information cont.

5. Privilege-Confusion Bugs: Privilege-confusion bugs allow unauthorized access to privileged functionality.

Impact

- Escalation of privileges.
- Unauthorized actions.
- Data exposure.

Mitigation

- Implement proper access controls.
- Regularly review privilege assignments.
- Follow the principle of least privilege.

Vulnerability information cont.

- Network Vulnerabilities: These relate to unprotected communication lines, man-in-the-middle attacks, insecure network architecture, and poor network security.

1. **Unprotected Communication Lines**: Unprotected communication lines refer to network channels (wired or wireless) that lack encryption or proper security measures.

Impact

- Data interception: Attackers can eavesdrop on sensitive information transmitted over the network.
- Unauthorized access: Lack of encryption allows unauthorized users to intercept and manipulate data packets.

Mitigation

- Use encryption protocols (e.g., HTTPS, TLS/SSL) for secure communication.
- Implement virtual private networks (VPNs) for encrypted data transmission.

Vulnerability information cont.

Some ways to protect computer systems

1. Multi – Level Authentication / Two – factor authentication (2FA)

- This is an essential security practice in which a user must provide at least two different pieces of evidence to verify their identity and gain access to a system, application, or network. These multiple factors enhance security by making it significantly more difficult for unauthorized individuals to gain access.

Points to note about 2FA

a) Factors for Authentication

- Requires users to present two or more of the following factors:
- **Knowledge Factor**: Something the user knows (e.g., a password or PIN).
- **Possession Factor**: Something the user possesses (e.g., a smartphone, security token, or smart card).
- **Inherent Factor**: Something inherent to the user (e.g., biometrics like fingerprints or facial recognition).
- **Location Factor**: The user's physical location (used less frequently).

Vulnerability information cont.

How MFA Works

- When logging in, the user provides their primary authentication (usually a password).
- Then, they must provide a secondary factor (e.g., a one-time code from an authenticator app, a fingerprint scan, or a smart card).
- Only when both factors are successfully verified does the user gain access.

Benefits of MFA

a. **Increased Security**: Even if an attacker obtains the user's password, they cannot proceed without the second factor.
b. **Protection Against Credential Theft**: Stolen passwords alone are insufficient for unauthorized access.
c. **Reduced Risk of Unauthorized Access**: MFA adds an extra layer of defense against cyber threats.

Vulnerability information cont.

Common MFA Methods:

- **SMS or Email Codes**: A one-time code sent via SMS or email.
- **Authenticator Apps**: Apps like Google Authenticator or Microsoft Authenticator generate time-based codes.
- **Biometrics**: Fingerprint scans, facial recognition, or voice recognition.
- **Hardware Tokens**: Physical devices that generate codes.
- **Smart Cards**: Cards with embedded chips for authentication.

Vulnerability information cont.

2. **Cloud security**

Understand Your Shared Responsibility Model:

- Cloud providers follow a shared responsibility model. While they secure the underlying infrastructure, customers are responsible for securing their data, applications, and access controls. Understand the division of responsibilities to ensure comprehensive security.

Ask Your Cloud Provider Detailed Security Questions:

- Before choosing a cloud provider, inquire about their security practices, certifications, and compliance. Understand how they handle data encryption, access controls, and incident response.

Vulnerability information cont.

Deploy an Identity and Access Management (IAM) Solution

- **IAM** ensures proper authentication and authorization. Implement strong authentication methods (such as MFA) and restrict access based on roles and permissions. IAM helps **keep hackers out** and **grant precise permissions**.

Train Your Staff

- Educate employees about cloud security best practices. Regular training helps prevent common mistakes and ensures awareness of security risks.

Establish and Enforce Cloud Security Policies

Define clear policies for data handling, encryption, incident response, and compliance. Regularly review and enforce these policies across the organization.

Vulnerability information cont.

Secure Your Endpoints

- Endpoints (devices accessing cloud resources) are vulnerable points. Use endpoint protection tools, keep software updated, and monitor for suspicious activity

Encrypt Data in Motion and At Rest

- Use encryption to protect data both during transmission (e.g., HTTPS) and when stored in the cloud. Encryption ensures confidentiality and integrity.

Use Intrusion Detection and Prevention Technology

- Implement intrusion detection and prevention systems (IDS/IPS) to monitor network traffic, detect anomalies, and prevent unauthorized access.

Vulnerability information cont.

3. International Cooperation and Threat Sharing

- Global cybersecurity requires collaboration among nations, international organizations, and private sectors. Sharing threat intelligence helps identify emerging risks and respond effectively.

Cyber Diplomacy and Norms

- Establishing norms of behavior in cyberspace is essential. Diplomatic efforts aim to prevent cyber conflicts, promote responsible behavior, and address state-sponsored cyber threats.

Critical Infrastructure Protection

- Critical infrastructure (such as power grids, transportation systems, and financial networks) spans borders. Cooperation ensures robust security against cyberattacks that could disrupt essential services.

Vulnerability information cont.

Cybercrime and Transnational Threats

- Cybercriminals operate globally, exploiting vulnerabilities in different jurisdictions. International cooperation is crucial for investigating and prosecuting cybercriminals.

Global Supply Chain Security

- Supply chains are interconnected across countries. Ensuring the security of hardware, software, and components is vital to prevent supply chain attacks.

Cyberwarfare and Geopolitical Tensions

- Geopolitical conflicts spill into cyberspace. Nations must address cyberwarfare risks, deterrence strategies, and rules of engagement.

Vulnerability information cont.

Capacity Building and Technical Assistance

- Developing countries need support to enhance their cybersecurity capabilities. Capacity building programs and technical assistance foster global resilience.

International Cybersecurity Standards and Certifications

- Common standards ensure interoperability and trust. Organizations like **International Organisation for Standardization (ISO)** which is international and **National Institute of Standards and Technology (NIST)** which is US based, provide guidelines for secure practices.

Vulnerability information cont.

4. Viruses and identification

- The situation when some software or program is downloaded, at that time the virus enters the devices and changes its property in accordance with the attacker's requirement. So, that the attacker can easily extract any data from the device whenever he requires it. Therefore, standard **antivirus** is needed for protecting the devices.

5. **System security**

- This simply means the protection of computer systems, networks, and software applications from unauthorized access, data breaches, and cyber threats. It encompasses various measures and practices to ensure the confidentiality, integrity, and availability of information and resources within an organization.
- This is when the devices with their hardware, software, database, and memory are protected in all respect. So, there's no chance of leakage of information unwantedly.

Vulnerability information cont.

- **Access Controls**: Implement strict access controls to limit user privileges and prevent unauthorized access to sensitive data or critical systems.
- **Authentication and Authorization**: Use strong authentication methods (such as multi-factor authentication) and define clear authorization rules for users.
- **Encryption**: Encrypt data both in transit (e.g., using HTTPS) and at rest (e.g., encrypting files or databases).
- **Patch Management**: Regularly apply security patches and updates to fix vulnerabilities in operating systems, applications, and software.
- **Firewalls and Intrusion Detection Systems (IDS)**: Deploy firewalls to filter network traffic and IDS to detect and respond to suspicious activities.
- **Logging and Monitoring**: Maintain detailed logs and monitor system events to identify security incidents.
- **Secure Configuration**: Properly configure servers, routers, and other devices to minimize security risks.
- **Vulnerability Assessment and Penetration Testing**: Regularly assess system vulnerabilities and conduct penetration tests to identify weaknesses.
- **Incident Response Plans**: Develop and test incident response plans to handle security breaches effectively.

Vulnerability information cont.

6. Certified Ethical Hacker

Skilled personnel in cybersecurity that understand and counter cyber threats

However, there is need for certification in order for one to successfully become a Certified Ethical Hacker (CEH).

Career Opportunities

CEH professionals can work as:

- **Ethical Hackers**: Identifying and fixing vulnerabilities in systems.
- **Penetration Testers**: Assessing security measures and finding weaknesses.
- **Security Analysts**: Monitoring and responding to security incidents.
- **Security Consultants**: Advising organizations on security best practices.

Vulnerability information cont. Group work

- Four well balanced groups should be formed
- A leader to represent the group and act as the secretary should be chosen
- Groups to make slide presentations of about five minutes
- All members should participate
- Only what has been agreed by the whole group should be taken down by the secretary
- Time keeper would be the lecturer
- Analysis of the presentation would be made after every presentation
- Possibly, a score would be given by the whole class
- Group to adhere to the question and all phones should be on Airplane mode

Vulnerability information cont.

Questions

Group One

- You have been offered a job as an **IT Security Specialist** at a known bank locally. **Analyze** the types of vulnerabilities that you would asses and mitigate in the system of the organisation.

Group Two

- As an **IT Security Manager**, You have been assigned to create possible skills and requirements for a job advert for **IT Security systems Administrator**. **Identity** and **explain** 5 possible inclusions on the skills and requirements on the list of the advert to be published in the Times of Zambia and Zambia Daily mail Newspapers.

Vulnerability information cont.

Questions

Group Three

- You have just been promoted to the position of **Cybersecurity Manager** in your Organisation. **List** and **explain** some of your expected duties in the organisation

Group Four

- As a **Cybersecurity professional** in a Government Department, **identify** and **discuss** how you would address software and hardware vulnerabilities.

Resources

Vulnerability scanning

- **Vulnerability scanning**, also known as **vulnerability assessment**, involves evaluating networks or IT assets for security vulnerabilities—flaws or weaknesses that external or internal threat actors can exploit.
- It serves as the **first stage** of the broader **vulnerability management lifecycle**.
- In most organizations today, vulnerability scans are **fully automated** and carried out by specialized scanning tools.

Importance of Vulnerability Scanning:

1. Unfortunately, vulnerabilities are often discovered by hackers before organizations can address them.
2. To adopt a more proactive security posture, IT teams implement **vulnerability management programs**.
3. Vulnerability scans are typically the **first step** in this process, helping identify security weaknesses before cybercriminals can exploit them.

Resources cont.

Vulnerability scanning tools

1. **Acunetix**:

- **License**: Commercial
- **Platforms**: Windows, Linux, MacOS
- **Note**: A free version with limited capabilities is also available.

2. Network mapper (Nmap):

- **License**: Open-source
- **Platforms**: Most platforms supported
- **Description**: Nmap is a powerful network scanning tool that can discover hosts and services on a network. It is mostly used for security auditing.

Resources cont.

3. Nikto2:

- **License**: Free
- **Platforms**: Most platforms supported
- **Description**: Nikto2 is an open-source web scanner that detects security issues in web servers.

4. Arachni:

License: Free

Platforms: Most platforms supported

Description: Arachni is a web vulnerability scanner that focuses on web application security.

Resources cont.

6. Burp Suite:

- **License**: Commercial
- **Platforms**: Most platforms supported
- **Note**: A free version with limited capabilities is available.

7. Nessus Professional (highly recommended):

- **License**: Branded vulnerability scanner
- **Platforms**: Most platforms supported
- **Description**: Nessus is widely used for vulnerability assessment and compliance checks.

Resources cont.

7. OpenVAS:

- **License**: Open-source
- **Platforms**: Most platforms supported
- **Description**: OpenVAS is a powerful vulnerability framework for scanning networks and web applications.

Resources cont.

Research Analysis in **vulnerability assessments** involves examining vulnerabilities within a specific context to gain insights for the purposes of **solving problems** and **decision-making**.

Levels of Analysis:

- Vulnerability assessment methodologies vary based on the overarching conceptual framework chosen and the intended use of assessment results.
- Researchers analyze vulnerabilities at different levels, including:
- **Macro Level**: Examining vulnerabilities at a **broader scale** (e.g., regional or national).
- **Micro Level**: Focusing on individual households or communities.
- The choice of level impacts the assessment approach and the depth of analysis.

Resources cont.

Factors Considered:

Researchers assess vulnerabilities by considering various factors:

- **Systems Affected**: Which systems (e.g., infrastructure, networks) are vulnerable?
- **Data at Risk**: What sensitive data is exposed?
- **Business Functions**: Which critical business functions are susceptible to attacks?
- **Ease of Attack**: How easily can an attacker exploit the vulnerability?
- **Severity of Attack**: What impact would an attack have?
- **Potential Damage**: What harm could result from the vulnerability.

Resources cont.

Methodologies and Tools:

- Researchers use vulnerability assessment tools to identify and rank vulnerabilities.
- These tools automate scans, analyze system configurations, and provide severity scores.
- The goal is to prioritize mitigation efforts based on risk levels.

Principles of vulnerability assessments

The following principles of vulnerability assessments should be followed whether dealing with macro or micro level.

1. **Asset Discovery**: Identifying critical assets that need evaluation.
2. **Asset Prioritization**: Prioritizing assets based on their importance

Resources cont.

3. **Vulnerability Assessment**: Scrutinizing assets for vulnerabilities.
4. **Risk Assessment**: Analyzing the potential impact of identified vulnerabilities.
5. **Remediation**: Addressing vulnerabilities through corrective actions.
6. **Reporting**: Documenting findings and recommendations.
7. **Repeat**: Regularly reassessing vulnerabilities to adapt to changing conditions

Resources cont.

Technical reporting : A technical report is a formal document that presents Research Findings, Analyses, or results related to vulnerability assessments.

- **Research Results**: Technical reports often describe original research, experiments, or investigations conducted by a researcher (you).
- **Algorithms and Methods**: They may explain novel algorithms, data structures, or computational methods.
- **System Designs**: Reports can detail the design and implementation of software systems, hardware components, or network architectures.
- **Comparative Studies**: Some reports compare different approaches, tools, or technologies.
- **Case Studies**: Researchers may present real-world case studies or practical applications.

Resources cont.

Format of a Technical Report

1.Executive Summary:

- Provides an overview of the assessment.
- Includes the date range, purpose, and scope of the assessment.
- Summarizes key findings regarding risk to the client.

2. Scan Results:

- Explains the results of vulnerability scans.
- Categorizes and orders vulnerabilities based on severity.
- Describes the types of reports provided.

Resources cont.

3. Methodology:

- Details the tools and tests used for vulnerability scanning.
- Specifies the purpose of each scan, tool, and test.
- Includes information about testing environments.

4. Findings:

- Lists systems successfully scanned and any that were not.
- Provides reasons for systems not scanned.
- Includes an index of all identified vulnerabilities, categorized by severity.

Resources cont.

5. Risk Assessment:

- Explains risk categories (critical, high, medium, or low).
- Provides details on each vulnerability, including plugin name, description, and solution.

6. Recommendations:

- Offers a full list of actions the organisation or client should take.
- Suggests other security tools for assessing network security posture.
- Includes security policy and configuration recommendations.

Resources cont.

Example of a Vulnerability Assessment Technical Report

Find, an attachment for a physical and original Technical Report



What to look for

1. **Affected Systems**:

- **Identify** which systems, networks, and applications are part of the assessment.
- **Consider** both internal and external systems.

2. Data at Risk:

- **Determine** what sensitive data resides within the assessed systems.
- Understand which data could be compromised if vulnerabilities are exploited.

3. Business Functions:

- **Evaluate** which critical business functions rely on the assessed systems.
- **Consider** the impact of vulnerabilities on these functions.

What to look for cont.

4. Ease of Attack or Compromise:

- **Assess** how easily an attacker could exploit identified vulnerabilities.
- **Prioritize** vulnerabilities based on their exploitability.

5. Severity of an Attack:

- **Categorize** vulnerabilities by severity (e.g., critical, high, medium, or low).
- **Understand** the potential impact of each vulnerability.

6. Potential Damage:

- **Consider** the consequences if a vulnerability is successfully exploited.
- **Evaluate** the potential harm to the organization, data, and operations.